PLAYBOOK DE RESPUESTA

PB-09 | Vulnerabilidad crítica

Procedimiento estandarizado de triage y contención para PagoClaro C05

Caso C05: PagoClaro Fintech S.A.S.

Implementación de un SOC Nivel 1 | Ética del Hacking / Ciberseguridad Defensiva

Control documental	Versión 1.0 | 21 de octubre de 2026 Responsable documental: Analista SOC N1 del laboratorio. Alcance: procedimientos defensivos en activos autorizados; sin operaciones sobre terceros.
Activo / ámbito	8 estaciones Windows de operaciones, 3 portátiles Windows de gerencia, 5 macOS de desarrollo, 4 Ubuntu Server (bastión, réplica BD, API y respaldos). La prioridad final depende del activo afectado.

01. Objetivo

Priorizar CVE reales que afecten API pública, bastión, Ubuntu Server y librerías de pagos.

02. Disparador, fuente y umbral

Módulo de vulnerabilidades Wazuh y análisis de versión de paquetes. Umbral: CVSS crítico o explotación conocida con activo expuesto a Internet.

03. Severidad inicial y promoción

Media si CVE sin exposición; Alta con acceso desde Internet o explotación conocida; Crítica si hay explotación activa en componente transaccional.

04. Triage: validación paso a paso

1. Identificar CVE, paquete, versión y agente; confirmar que el software está presente.
2. Comprobar si el servicio está activo y expuesto en API o bastión.
3. Consultar fuentes oficiales del fabricante y disponibilidad de parche.
4. Verificar indicadores de explotación en eventos relevantes.
5. Calcular criticidad con impacto en pago, tokenización, llaves y continuidad.

05. Contención autorizada a N1

- Notificar a TI y proponer mitigación aprobada (restricción de acceso, WAF/IPS).
- Programar revalidación posterior mediante escaneo autorizado.

06. Acciones no autorizadas a N1

- No instalar parches sin cambio aprobado.
- No ejecutar pruebas explotativas sobre la producción.

07. Evidencia mínima preservada

- CVE, versión, host, paquete, fuente y fecha de detección.
- Referencia de parche/mitigación y evaluación de exposición.

08. Escalamiento obligatorio a N2

Explotación activa, API expuesta con criticidad alta, ausencia de mitigación o CVE sin parche en activo crítico.

09. Criterios de cierre técnico

Verificar corrección con nuevo inventario/escaneo; registrar excepción formal si subsiste.

10. Mejora continua

Revisar parcheo de software crítico y ventanas de mantenimiento para pagos.

11. Registro y trazabilidad

Bitácora del SOC: referencia INC-C05-AAAA-NNN, hora de la alerta (America/Bogota), activo, sensor, rule.id, analista, clasificación, evidencia inmutable, decisiones, autorización y hora de entrega/cierre. No incluir datos financieros sensibles.

12. Responsable, control de versión y fuente

Responsable: analista SOC N1 | Aprobación: responsable SOC | Versión: 1.0 | Revisión: 21/10/2026 | Fuente base: Parcial_SOC_N1_Etica_Hacking, PB-09 (Fase 6) y Anexo F. Los umbrales numéricos de esta adaptación son propuestas operativas, no detecciones que se haya comprobado activar.